Устоять любой ценой
Методы борьбы с DoS/DDoS-атаками

Содержание статьи

- Анатомия DoS-атак
- Методы борьбы
- Борьба с flood-атаками
- Универсальные советы
- Кажется, началось. Что делать?
- Борьба с DDoS во FreeBSD
- Наивный Internet
- Крупнейшие ботнеты
- След в истории
- Интеллектуальные системы
- INFO

Твое утро начинается с чтения багрепортов и анализа логов. Ты ежедневно обновляешь ПО и ежечасно дорабатываешь правила брандмауэра. Snort твой лучший друг, а Zabbix — невидимый помощник. Ты построил настоящий бастион, к которому не подобраться ни с одной стороны. Но! Ты совершенно беззащитен против самой коварной и подлой атаки на свете — DDoS.

Трудно сказать, когда впервые появился термин DoS-атака. Специалисты говорят о 1996-м, попутно намекая, что до широких масс этот тип атак "дошел" только в 1999 году, когда один за другим попадали web-сайты Amazon, Yahoo, CNN и eBay. Еще раньше DoS-эффект использовали для тестирования устойчивости систем и каналов связи. А если копнуть глубже и воспользоваться термином DoS для обозначения явления, то становится ясно, что он существовал всегда, со времен первых мейнфреймов. Вот только задумываться о нем как о средстве устрашения начали гораздо позже.

Говоря простым языком, DoS-атаки — это некоторый вид злонамеренной деятельности, ставящей своей целью довести компьютерную систему до такого состояния, когда она не сможет обслуживать правомерных пользователей или правильно выполнять возложенные на нее функции. К состоянию "отказ в обслуживании" обычно приводят ошибки в ПО или чрезмерная нагрузка на сетевой канал или систему в целом. В результате чего ПО, либо вся операционная система машины, "падает" или же оказывается в "зацикленном" состоянии. А это грозит простоями, потерей посетителей/клиентов и убытками.

Анатомия DoS-атак

DoS-атаки подразделяются на локальные и удаленные. К локальным относятся различные эксплойты, форк-бомбы и программы, открывающие по миллиону файлов или

запускающие некий циклический алгоритм, который сжирает память и процессорные ресурсы. На всем этом мы останавливаться не будем. А вот удаленные DoS-атаки рассмотрим подробнее. Они делятся на два вида:

1. Удаленная эксплуатация ошибок в ПО с целью привести его в нерабочее состояние.
2. Flood — посылка на адрес жертвы огромного количества бессмысленных (реже – осмысленных) пакетов. Целью флуда может быть канал связи или ресурсы машины. В первом случае поток пакетов занимает весь пропускной канал и не дает атакуемой машине возможность обрабатывать легальные запросы. Во втором — ресурсы машины захватываются с помощью многократного и очень частого обращения к какому-либо сервису, выполняющему сложную, ресурсоемкую операцию. Это может быть, например, длительное обращение к одному из активных компонентов (скрипту) web-сервера. Сервер тратит все ресурсы машины на обработку запросов атакующего, а пользователям приходится ждать.

В традиционном исполнении (один атакующий — одна жертва) сейчас остается эффективным только первый вид атак. Классический флуд бесполезен. Просто потому что при сегодняшней ширине канала серверов, уровне вычислительных мощностей и повсеместном использовании различных анти-DoS приемов в ПО (например, задержки при многократном выполнении одних и тех же действий одним клиентом), атакующий превращается в надоедливого комара, не способного нанести какой бы то ни было ущерб. Но если этих комаров наберутся сотни, тысячи или даже сотни тысяч, они легко положат сервер на лопатки. Толпа — страшная сила не только в жизни, но и в компьютерном мире. Распределенная атака типа "отказ в обслуживании" (DDoS), обычно осуществляемая с помощью множества зомбифицированных хостов, может отрезать от внешнего мира даже самый стойкий сервер, и единственная эффективная защита — организация распределенной системы серверов (но это по карману далеко не всем, привет Google).

Методы борьбы

Опасность большинства DDoS-атак – в их абсолютной прозрачности и "нормальности". Ведь если ошибка в ПО всегда может быть исправлена, то полное сжирание ресурсов — явление почти обыденное. С ними сталкиваются многие администраторы, когда ресурсов машины (ширины канала) становится недостаточно, или web-сайт подвергается слэшдот-эффекту (twitter.com стал недоступен уже через несколько минут после первого известия о смерти Майкла Джексона). И если резать трафик и ресурсы для всех подряд, то спасешься от DDoS, но потеряешь добрую половину клиентов.

Выхода из этой ситуации фактически нет, однако последствия DDoS-атак и их эффективность можно существенно снизить за счет правильной настройки маршрутизатора, брандмауэра и постоянного анализа аномалий в сетевом трафике. В следующей части статьи мы последовательно рассмотрим:

- способы распознавания начинающейся DDoS-атаки;
- методы борьбы с конкретными типами DDoS-атак;

- универсальные советы, которые помогут подготовиться к DoS-атаке и снизить ее эффективность.

В самом конце будет дан ответ на вопрос: что делать, когда началась DDoS-атака.

Борьба с flood-атаками

Итак, существует два типа DoS/DDoS-атак, и наиболее распространенная из них основана на идее флуда, то есть заваливания жертвы огромным количеством пакетов. Флуд бывает разным: ICMP-флуд, SYN-флуд, UDP-флуд и HTTP-флуд. Современные DoS-боты могут использовать все эти виды атак одновременно, поэтому следует заранее позаботиться об адекватной защите от каждой из них.

1. ICMP-флуд.

Очень примитивный метод забивания полосы пропускания и создания нагрузок на сетевой стек через монотонную посылку запросов ICMP ECHO (пинг). Легко обнаруживается с помощью анализа потоков трафика в обе стороны: во время атаки типа ICMP-флуд они практически идентичны. Почти безболезненный способ абсолютной защиты основан на отключении ответов на запросы ICMP ECHO:

```
# sysctl net.ipv4.icmp_echo_ignore_all=1
```

Или с помощью брандмауэра:

```
# iptables -A INPUT -p icmp -j DROP --icmp-type 8
```

2. SYN-флуд.

Один из распространенных способов не только забить канал связи, но и ввести сетевой стек операционной системы в такое состояние, когда он уже не сможет принимать новые запросы на подключение. Основан на попытке инициализации большого числа одновременных TCP-соединений через посылку SYN-пакета с несуществующим обратным адресом. После нескольких попыток отослать ответный ACK-пакет на недоступный адрес большинство операционок ставят неустановленное соединение в очередь. И только после n-ой попытки закрывают соединение. Так как поток ACK-пакетов очень велик, вскоре очередь оказывается заполненной, и ядро дает отказ на попытки открыть новое соединение. Наиболее умные DoS-боты еще и анализируют систему перед началом атаки, чтобы слать запросы только на открытые жизненно важные порты. Идентифицировать такую атаку просто: достаточно попробовать подключиться к одному из сервисов. Оборонительные мероприятия обычно включают в себя:

Увеличение очереди "полуоткрытых" TCP-соединений:

```
# sysctl -w net.ipv4.tcp_max_syn_backlog=1024
```

Уменьшение времени удержания "полуоткрытых" соединений:

```
# sysctl -w net.ipv4.tcp_synack_retries=1
```

Включение механизма TCP syncookies:

```
# sysctl -w net.ipv4.tcp_syncookies=1
```

Ограничение максимального числа "полуоткрытых" соединений с одного IP к конкретному порту:

```
# iptables -I INPUT -p tcp --syn --dport 80 -m iplimit
--iplimit-above
10 -j DROP
```

3. UDP-флуд.

Типичный метод захламления полосы пропускания. Основан на бесконечной посылке UDP-пакетов на порты различных UDP-сервисов. Легко устраняется за счет отрезания таких сервисов от внешнего мира и установки лимита на количество соединений в единицу времени к DNS-серверу на стороне шлюза:

iptables -I INPUT -p udp —dport 53 -j DROP -m iplimit —iplimit-above 1

4. HTTP-флуд.

Один из самых распространенных на сегодняшний день способов флуда. Основан на бесконечной посылке HTTP-сообщений GET на 80-ый порт с целью загрузить web-сервер настолько, чтобы он оказался не в состоянии обрабатывать все остальные запросы. Часто целью флуда становится не корень web-сервера, а один из скриптов, выполняющих ресурсоемкие задачи или работающий с базой данных. В любом случае, индикатором начавшейся атаки будет служить аномально быстрый рост логов web-сервера.

Методы борьбы с HTTP-флудом включают в себя тюнинг web-сервера и базы данных с целью снизить эффект от атаки, а также отсеивание DoS-ботов с помощью различных приемов. Во-первых, следует увеличить максимальное число коннектов к базе данных одновременно. Во-вторых, установить перед web-сервером Apache легкий и производительный nginx – он будет кэшировать запросы и отдавать статику. Это решение из списка "must have", которое не только снизит эффект DoS-атак, но и позволит серверу выдержать огромные нагрузки. Небольшой пример:

```
# vi /etc/nginx/nginx.conf
# Увеличиваем максимальное количество используемых файлов
worker_rlimit_nofile 80000;
events {
# Увеличиваем максимальное количество соединений
worker_connections 65536;
# Использовать эффективный метод epoll для обработки
соединений
use epoll;
}
http {
gzip off;
# Отключаем таймаут на закрытие keep-alive соединений
keepalive_timeout 0;
# Не отдавать версию nginx в заголовке ответа
```

```
server_tokens off;
# Сбрасывать соединение по таймауту
reset_timedout_connection on;
}
# Стандартные настройки для работы в качестве прокси
server {
listen 111.111.111.111 default deferred;
server_name host.com www.host.com;
log_format IP $remote_addr;
location / {
proxy_pass http://127.0.0.1/;
}
location ~* \.(jpeg|jpg|gif|png|css|js|pdf|txt|tar)$ {
root /home/www/host.com/httpdocs;
}
}
```

В случае необходимости можно задействовать nginx-модуль ngx_http_limit_req_module, ограничивающий количество одновременных подключений с одного адреса (http://sysoev.ru/nginx/docs/http/ngx_http_limit_req_module.html). Ресурсоемкие скрипты можно защитить от ботов с помощью задержек, кнопок "Нажми меня", выставления кукисов и других приемов, направленных на проверку "человечности".

Универсальные советы

Чтобы не попасть в безвыходное положение во время обрушения DDoS-шторма на системы, необходимо тщательным образом подготовить их к такой ситуации:

1. Все сервера, имеющие прямой доступ во внешнюю сеть, должны быть подготовлены к простому и быстрому удаленному ребуту (sshd спасет отца русской демократии). Большим плюсом будет наличие второго, административного, сетевого интерфейса, через который можно получить доступ к серверу в случае забитости основного канала.
2. ПО, используемое на сервере, всегда должно находиться в актуальном состоянии. Все дырки — пропатчены, обновления установлены (простой, как сапог, совет, которому многие не следуют). Это оградит тебя от DoS-атак, эксплуатирующих баги в сервисах.
3. Все слушающие сетевые сервисы, предназначенные для административного использования, должны быть спрятаны брандмауэром ото всех, кто не должен иметь к ним доступ. Тогда атакующий не сможет использовать их для проведения DoS-атаки или брутфорса.
4. На подходах к серверу (ближайшем маршрутизаторе) должна быть установлена система анализа трафика (NetFlow в помощь), которая позволит своевременно узнать о начинающейся атаке и вовремя принять меры по ее предотвращению.

Добавь в /etc/sysctl.conf следующие строки:

```
# vi /etc/sysctl.conf
# Защита от спуфинга
net.ipv4.conf.default.rp_filter = 1
# Проверять TCP-соединение каждую минуту. Если на другой
стороне - легальная
машина, она сразу ответит. Дефолтовое значение - 2 часа.
net.ipv4.tcp_keepalive_time = 60
# Повторить пробу через десять секунд
net.ipv4.tcp_keepalive_intvl = 10
# Количество проверок перед закрытием соединения
net.ipv4.tcp_keepalive_probes = 5
```

Следует отметить, что все приемы, приведенные в прошлом и этом разделах, направлены на снижение эффективности DDoS-атак, ставящих своей целью израсходовать ресурсы машины. От флуда, забивающего канал мусором, защититься практически невозможно, и единственно правильный, но не всегда осуществимый способ борьбы заключается в том, чтобы "лишить атаку смысла". Если ты заимеешь в свое распоряжение действительно широкий канал, который легко пропустит трафик небольшого ботнета, считай, что от 90% атак твой сервер защищен. Есть более изощренный способ защиты. Он основан на организации распределенной вычислительной сети, включающей в себя множество дублирующих серверов, которые подключены к разным магистральным каналам. Когда вычислительные мощности или пропускная способность канала заканчиваются, все новые клиенты перенаправляются на другой сервер (или же постепенно "размазываются" по серверам по принципу round-robin). Это невероятно дорогая, но очень стойкая структура, завалить которую практически нереально.

Другое более-менее эффективное решение заключается в покупке дорогостоящих хардварных систем Cisco Traffic Anomaly Detector и Cisco Guard. Работая в связке, они могут подавить начинающуюся атаку, но, как и большинство других решений, основанных на обучении и анализе состояний, дают сбои. Поэтому следует хорошенько подумать перед тем, как выбивать из начальства десятки тысячи долларов на такую защиту.

Кажется, началось. Что делать?

Перед непосредственным началом атаки боты "разогреваются", постепенно наращивая поток пакетов на атакуемую машину. Важно поймать момент и начать активные действия. Поможет в этом постоянное наблюдение за маршрутизатором, подключенным к внешней сети (анализ графиков NetFlow). На сервере-жертве определить начало атаки можно подручными средствами.

Наличие SYN-флуда устанавливается легко — через подсчет числа "полуоткрытых" TCP-соединений:

```
# netstat -na | grep ":80\ " | grep SYN_RCVD
```

В обычной ситуации их не должно быть совсем (или очень небольшое количество: максимум 1-3). Если это не так — ты атакован, срочно переходи к дропанью атакующих.

С HTTP-флудом несколько сложнее. Для начала нужно подсчитать количество процессов Apache и количество коннектов на 80-ый порт (HTTP-флуд):

```
# ps aux | grep httpd | wc -l
# netstat -na | grep ":80\ " | wc -l
```

Значения, в несколько раз превышающие среднестатистические, дают основания задуматься. Далее следует просмотреть список IP-адресов, с которых идут запросы на подключение:

```
# netstat -na | grep ":80\ " | sort | uniq -c | sort -nr | less
```

Однозначно идентифицировать DoS-атаку нельзя, можно лишь подтвердить свои догадки о наличии таковой, если один адрес повторяется в списке слишком много раз (да и то, это может говорить о посетителях, сидящих за NAT'ом). Дополнительным подтверждением будет анализ пакетов с помощью tcpdump:

```
# tcpdump -n -i eth0 -s 0 -w output.txt dst port 80 and host IP-сервера
```

Показателем служит большой поток однообразных (и не содержащих полезной информации) пакетов от разных IP, направленных на один порт/сервис (например, корень web-сервера или определенный cgi-скрипт).

Окончательно определившись, начинаем дропать неугодных по IP-адресам (будет гораздо больше эффекта, если ты сделаешь это на маршрутизаторе):

```
# iptables -A INPUT -s xxx.xxx.xxx.xxx -p tcp --destination-port http -j
DROP
```

Или сразу по подсетям:

```
# iptables -A INPUT -s xxx.xxx.0.0/16 -p tcp --destination-port http -j
DROP
```

Это даст тебе некоторую фору (совсем маленькую; зачастую IP-адрес источника спуфится), которую ты должен использовать для того, чтобы обратиться к провайдеру/хостеру (с приложенными к сообщению логами web-сервера, ядра, брандмауэра и списком выявленных тобой IP-адресов). Большинство из них, конечно, проигнорируют это сообщение (а хостинги с оплатой трафика еще и порадуются — DoS-атака принесет им прибыль) или просто отключат твой сервер. Но в любом случае это следует сделать обязательно, – эффективная защита от DDoS возможна только на магистральных каналах. В одиночку ты справишься с мелкими нападками, направленными на истощение ресурсов сервера, но окажешься беззащитным перед более-менее серьезным DDoS'ом.

Борьба с DDoS во FreeBSD

Уменьшаем время ожидания ответного пакета на запрос SYN-ACK (защита от SYN-флуда):

```
# sysctl net.inet.tcp.msl=7500
```

Превращаем сервер в черную дыру. Так ядро не будет слать ответные пакеты при попытке подключиться к незанятым портам (снижает нагрузку на машину во время DDoS’а на случайные порты):

```
# sysctl net.inet.tcp.blackhole=2
# sysctl net.inet.udp.blackhole=1
```

Ограничиваем число ответов на ICMP-сообщения 50-ю в секунду (защита от ICMP-флуда):

```
# sysctl net.inet.icmp.icmplim=50
```

Увеличиваем максимальное количество подключений к серверу (защита от всех видов DDoS):

```
# sysctl kern.ipc.somaxconn=32768
```

Включаем DEVICE_POLLING — самостоятельный опрос сетевого драйвера ядром на высоких нагрузках (существенно снижает нагрузку на систему во время DDoS’а):

1. Пересобираем ядро с опцией "options DEVICE_POLLING";
2. Активируем механизм поллинга: "sysctl kern.polling.enable=1";
3. Добавляем запись "kern.polling.enable=1" в /etc/sysctl.conf.

Наивный Internet

Во времена своего рассвета DoS-атаки были настоящей катастрофой для серверов и обычных рабочих станций. Web-сайт можно было легко завалить с помощью одного-единственного хоста, реализующего атаку типа Smurf. Рабочие станции с установленной ОС Windows падали, как доминошки, от атак типа Ping of Death, Land, WinNuke. Сегодня всего этого не стоит опасаться.

Крупнейшие ботнеты

Kraken — 400 тысяч компьютеров.
Srizbi — 315 тысяч компьютеров.
Bobax — 185 тысяч компьютеров.
Rustock — 150 тысяч компьютеров.
Storm — 100 тысяч компьютеров.
Psybot — 100 тысяч ADSL-маршрутизаторов, основанных на Linux.
Ботнет BBC — 22 тысячи компьютеров.
Экспериментальный ботнет, созданный компанией BBC.

След в истории

1997 год — DDoS-атака на web-сайт Microsoft. Один день молчания.

1999 год – "вне зоны действия" оказались web-сайты Yahoo, CNN, eBay и др.

Октябрь 2002 — атака на корневые DNS-серверы интернета. На некоторое время были выведены из строя 7 из 13 серверов.

21 февраля 2003 года — DDoS-нападение на LiveJournal.com. Два дня сервис находился в парализованном состоянии, лишь иногда подавая признаки жизни.

Интеллектуальные системы

Интересную альтернативу решениям Cisco выпускает компания Reactive Networks (www.reactivenetworks.com).

Их продукт под названием FloodGuard представляет собой аппаратный комплекс, состоящий из детекторов и исполнительных модулей. Детекторы, установленные на брандмауэрах, маршрутизаторах и свитчах, постоянно мониторят трафик и создают его профиль на основе таких параметров, как объем пакетов, источник, направление, тип и т.д. В случае возникновения аномалий детектор посылает все подробности о произошедшем исполнительным модулям, располагающимся на маршрутизаторах в разных сегментах сети. Получив сообщение от детектора, исполнительные модули начинают действовать: они отыскивают паразитный трафик в проходящих пакетах и, в случае удачи, оповещают об этом предыдущие по ходу трафика модули и посылают им инструкции по активации фильтров на маршрутизаторах. В результате, перед потоком флуд-трафика должен образоваться заслон, который будет быстро перемещаться в сторону его источника.

INFO

Подробнее о протоколе NetFlow можно прочитать в статье "Поток пакетов — на контроль!", опубликованной в июльском номере][за 2007 год.

Round-robin — алгоритм выравнивания нагрузки распределенной вычислительной системы методом перебора ее элементов по круговому циклу.

В поставку OpenBSD входит утилита tcpdrop(8), с помощью которой можно отбросить TCP-подключение (tcpdrop 192.168.1.1:80 192.168.1.12:26747).